

HiveForce Labs

THREAT ADVISORY

 **VULNERABILITY REPORT**

GitLab Fixes Multiple Flaws, Urges Immediate User Patching

Date of Publication

September 13, 2024

Admiralty Code

A1

TA Number

TA2024354

Summary

First Seen: September 2024

Affected Products: GitLab Community Edition (CE) and Enterprise Edition (EE)

Impact: GitLab has released security updates to fix several vulnerabilities, including the critical CVE-2024-6678 flaw, which allows attackers to run pipeline jobs as any user. GitLab recommends that all installations running affected versions upgrade to the latest patched releases (17.3.2, 17.2.5, and 17.1.7) immediately to mitigate potential security risks.

⚙ CVEs

CVE	NAME	AFFECTED PRODUCTS	ZERO-DAY	CISA	PATCH
CVE-2024-6678	GitLab Community and Enterprise Editions Authentication Bypass Vulnerability	GitLab CE/EE	✗	✗	✓
CVE-2024-8640	GitLab Community and Enterprise Editions Command Injection Vulnerability	GitLab CE/EE	✗	✗	✓
CVE-2024-8635	GitLab Community and Enterprise Editions Server-Side Request Forgery (SSRF) Vulnerability	GitLab CE/EE	✗	✗	✓
CVE-2024-8124	GitLab Community and Enterprise Editions Denial of Service Vulnerability	GitLab CE/EE	✗	✗	✓

Vulnerability Details

#1 GitLab has rolled out crucial security updates for its Community Edition (CE) and Enterprise Edition (EE) platforms to address multiple vulnerabilities, including the critical CVE-2024-6678. This particular flaw is the most severe, as it enables remote attackers to bypass access controls and run pipeline jobs as arbitrary users. Such a weakness could lead to unauthorized operations and potential system compromise, stemming from GitLab’s improper access restriction mechanisms.

#2

In addition to CVE-2024-6678, GitLab has patched three other high-severity vulnerabilities. CVE-2024-8635 is a Server-Side Request Forgery (SSRF) flaw in GitLab EE that could allow attackers to exploit the Dependency Proxy URL to access internal systems, potentially compromising sensitive infrastructure. CVE-2024-8124, a denial-of-service (DoS) vulnerability affecting both GitLab CE and EE, can be triggered by a malformed `glm\_source` parameter, potentially leading to service disruptions. Finally, CVE-2024-8640 is a command injection flaw in GitLab EE caused by insufficient input validation in interactions with connected Cube servers, allowing attackers to execute arbitrary commands.

#3

The risks posed by these vulnerabilities are significant, as successful exploitation could lead to unauthorized system access, and service disruption. GitLab has urged all users to immediately upgrade to the latest patched versions to safeguard against potential attacks and mitigate security risks.

Vulnerabilities

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2024-6678	GitLab CE/EE All versions starting from 8.14 prior to 17.1.7, starting from 17.2 prior to 17.2.5, and starting from 17.3 prior to 17.3.2	cpe:2.3:a:gitlab:gitlab:*:*:*:*:*	CWE-290
CVE-2024-8640	GitLab CE/EE All versions starting from 16.11 prior to 17.1.7, from 17.2 prior to 17.2.5, and from 17.3 prior to 17.3.2	cpe:2.3:a:gitlab:gitlab:*:*:*:*:*	CWE-77
CVE-2024-8635	GitLab CE/EE all versions starting from 16.8 prior to 17.1.7, from 17.2 prior to 17.2.5, and from 17.3 prior to 17.3.2	cpe:2.3:a:gitlab:gitlab:*:*:*:*:*	CWE-918
CVE-2024-8124	GitLab CE/EE All versions starting from 16.4 prior to 17.1.7, starting from 17.2 prior to 17.2.5, starting from 17.3 prior to 17.3.2	cpe:2.3:a:gitlab:gitlab:*:*:*:*:*	CWE-1333

Recommendations



Updated: All users are urged to upgrade their installations of GitLab Community Edition (CE) and Enterprise Edition (EE) to the latest patched versions (17.3.2, 17.2.5, and 17.1.7) immediately to address critical security vulnerabilities.



Disable Vulnerable Features: If immediate upgrading is not feasible, consider temporarily disabling features related to pipeline execution until the upgrade can be performed. This may reduce the attack surface while still allowing other functionalities to operate.



Restrict Access to CI/CD: Limit access to CI/CD features to trusted users only. Implementing strict access controls can help mitigate the risk of exploitation from unauthorized users.



Vulnerability Management: Implement a robust vulnerability management process to ensure that software and systems are regularly assessed for vulnerabilities and updated with the required security patches. Prioritize critical vulnerabilities identified by security advisories and vendors to mitigate the risk of exploitation by threat actors.

Potential MITRE ATT&CK TTPs

<u>TA0042</u> Resource Development	<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0040</u> Impact
<u>T1588</u> Obtain Capabilities	<u>T1588.006</u> Vulnerabilities	<u>T1190</u> Exploit Public-Facing Application	<u>T1059</u> Command and Scripting Interpreter
<u>T1499</u> Endpoint Denial of Service			

Patch Details

GitLab users should immediately update their Community Edition (CE) and Enterprise Edition (EE) installations to the latest versions (17.3.2, 17.2.5, and 17.1.7) to fix critical security vulnerabilities.

Link: <https://about.gitlab.com/update/>

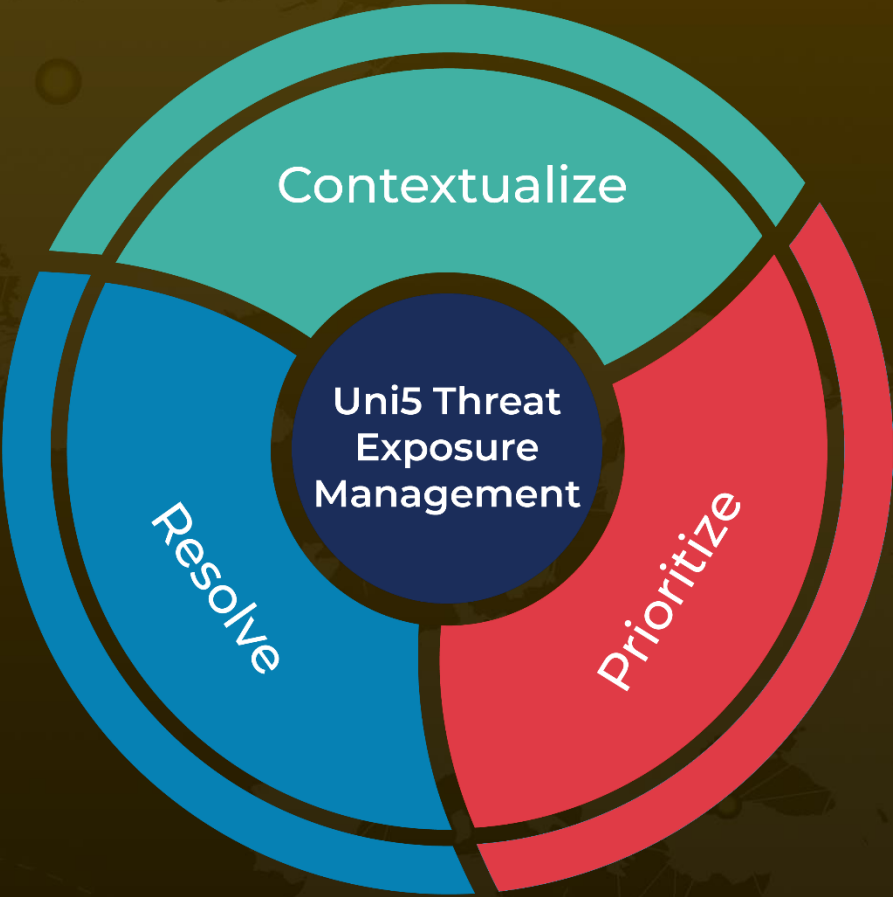
References

<https://about.gitlab.com/releases/2024/09/11/patch-release-gitlab-17-3-2-released/>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

September 13, 2024 • 6:40 AM

© 2024 All Rights are Reserved by Hive Pro



More at www.hivepro.com